

Per-Issuance Authorization Non-Amplification under Chosen-Context Signature Collection

Iman Schrock
EMILIA Protocol, Inc.
team@emiliaprotocol.ai
ORCID: 0009-0004-0290-5433

Preprint v5. August 2026.

Abstract

A valid signature proves that a key signed a message. It does not say how many actions an executor may perform with that message. This gap matters when an untrusted collector can ask honest signers to approve adaptively chosen requests, retain the resulting artifacts, and present them concurrently to several executors. Replaying one genuine approval can then cause two provider entries without forging any signature.

We formalize this gap as *authorization non-amplification* (ANA). In a finite multi-user experiment, the adversary wins if a provider entry lacks a prior issuance record or, for any required key unrevealed before entry, lacks an earlier signing event for the accepted context and slot. The adversary also wins if one issued instance witnesses more than one provider entry. We show that neither EUF-CMA security nor signer-to-collector injective agreement implies ANA.

Our construction combines EUF-CMA signatures, a collision-resistant hash, injective typed encodings, an ideal exact issue-and-consume resource, and a one-use provider mediator. Except for setup-key collision, an entry without the required witness yields either a signature forgery or a hash collision; the state resources rule out duplicate entry. A separate bound names the registry and mediation failures that a real implementation must control. Four Tamarin models illustrate the correspondence, while nine weakened variants produce the expected attacks. The result concerns provider entry only; it does not establish human identity, display fidelity, policy correctness, or exactly-once physical effect.

1 Introduction

Digital signatures answer a message-authenticity question: did a holder of a particular key sign these bytes? Consequential authorization adds a different question: how many provider entries may those bytes authorize? The second answer is not contained in the first.

Consider a service that asks an enrolled approver to sign a transfer, release, deployment, or control action. The service may be honest, but the security boundary should survive a compromised collector. Such a collector can request many genuine signatures, choose the order in which requests are shown, retain old artifacts, combine signatures obtained at different times, and race the same artifact through several executors. None of those operations requires a signature forgery.

This paper studies that collector as the adversary. The adversary chooses the semantic authorization context, subject to a closed typed grammar, and obtains genuine signatures from uncompromised pinned keys. It also controls transport, storage, scheduling, and presentation. The intended guarantee is deliberately narrow: if an executor crosses a provider boundary, the exact admitted action must have one prior issued authorization instance and, for each then-unrevealed required key, a prior signing event on the exact slot message; one issued instance must not account for two entries.

We call the guarantee *authorization non-amplification* (ANA). For a trace T , let

$$\text{amp}_T(d, u) = |\{e : e = \text{Entry}(d, u, h, \tau, a, c, S) \text{ occurs in } T\}|.$$

The cardinality clause is $\text{amp}_T(d, u) \leq 1$ for every issued instance key (d, u) ; this is replay prevention at the provider-entry boundary. The witness clause is separate: it relates each entry to one exact trusted issuance record and to every exact slot-message signing event required by the policy recorded in that issuance.

Our research question is:

When a collector may obtain genuine signatures on adaptively chosen authorization contexts, what assumptions ensure that each provider entry is backed by the exact issued context and that one issuance cannot unlock two entries?

We answer it with a finite multi-user experiment in which the adversary wins by causing an unwitnessed provider entry or by using one issued instance for two entries. We prove a construction in an ideal-resource model and a refinement bound that exposes concrete registry and mediation failures. ANA is not a new correspondence logic. It is a security game for a particular cross-role correspondence—from issuance and signer events to executor entry—under chosen-context collection, adaptive reveal, and concurrent admission. The proof separates three obligations that are often collapsed:

1. **Message authenticity.** Every unrevealed required key signed the exact accepted typed context.
2. **Authorization-instance coherence.** Every required signature and the executor refer to the same independently issued context and pinned policy. This does not claim that approvers were contemporaneous or mutually aware.
3. **Non-amplification.** The trusted issue-and-consume record that witnesses one provider entry cannot witness another.

The distinction is cryptographically useful. EUF-CMA counts previously unsigned messages; ANA counts admitted actions. Lowe’s injective agreement is parameterized by roles and agreed data and relates protocol runs between peers [2]; ANA uses standard correspondence machinery but relates authorization evidence to an executor’s provider-entry events. Section 5 proves that EUF-CMA and a signer-to-collector agreement claim do not supply the missing entry bound.

The paper makes five concrete contributions:

- a finite multi-user, chosen-authorization-context experiment with explicit issuance, signing, reveal, verification, consumption, and provider-entry events;
- a witness-based ANA definition that combines exact semantic coverage, pinned-policy fidelity, and an injective map from entries to issued instances;
- a construction from standard signatures and hashes plus an ideal exact issue-and-consume resource and a one-use mediator;
- a reduction whose multi-user sum ranges over every enrolled challenge key, not merely the keys selected by a winning policy, together with exact query and runtime accounting; and
- separation results and machine-checked case studies showing why a random nonce, an authentic signature, or signer-to-collector injective agreement does not by itself make an authorization single-use at the provider boundary.

Table 1 matches each claim to its load-bearing assumption. The single-use result depends on linearizable consume state and complete mediation, not on signature unforgeability.

The strongest claims stop at provider entry. A provider may fail, time out, or perform an effect whose acknowledgement is lost. ANA therefore forbids a blind retry after an indeterminate entry, but it does not claim exactly-once physical execution. It also does not prove that a key belongs to a particular person or that a display faithfully represented the signed action.

Table 1: Result map and claim boundary.

Claim	Load-bearing assumption	Not established
Exact signed-context witness	EUF-CMA signatures, collision resistance, injective typed encodings, pinned keys	human identity, display fidelity, signer independence
One entry per issued instance	linearizable exact consume and complete provider mediation	one effect, successful effect, or truthful acknowledgement
Later-reveal prefix authenticity	no key reveal before the entry event and an ordered experiment trace	forward security or offline anti-backdating
Real deployment bound	explicit registry- and mediation-break probabilities	negligible operational failure without a separate argument

2 Setting and Syntax

2.1 Stateful authorization-admission schemes

A stateful authorization-admission scheme exposes the following polynomial-time interfaces over a totally ordered trace:

- Setup**(1^λ). Create public parameters, certified signer keys, trusted issuer state, and executor state.
- Issue**(x). Validate an authorization request x , atomically create one immutable issued instance, emit its issuance event, and return a public instance identifier and context.
- Approve**(j, u, s). For certified signer j and policy slot s , return evidence over the exact issued context identified by u and emit the corresponding signing event.
- Admit**(d, u, a, S). Verify the issued context, action, policy, and finite evidence map S ; perform the scheme’s one-time state transition; and either refuse or emit one provider entry.
- Reveal**(j). Reveal signer j ’s secret key and emit a reveal event.

Correctness requires that a valid issuance followed by every required approval and one admission of the exact issued action emits one entry, while a repeated admission of that issued instance is refused. Security is defined over the trace in Section 4. This syntax is deliberately stateful: Proposition 1 shows that a complete stateless realization cannot satisfy the cardinality clause.

2.2 Signature and hash assumptions

Let $\text{Sig} = (\text{Kg}, \text{Sign}, \text{Verify})$ be a signature scheme. For each enrolled index $j \in [N]$, the challenger samples $(sk_j, pk_j) \leftarrow \text{Kg}(1^\lambda)$. We use standard existential unforgeability under adaptive chosen-message attack and write $\text{Adv}_{\text{Sig}}^{\text{euf-cma}}(\mathcal{B})$ for the success probability of a forger $\mathcal{B}$ [1].

For completeness, the EUF-CMA experiment gives pk and oracle access to $\text{Sign}(sk, \cdot)$ to $\mathcal{B}$. Let Q be the set of exact byte strings submitted to that oracle. The forger outputs (m^*, σ^*) and wins when $\text{Verify}(pk, m^*, \sigma^*) = 1$ and $m^* \notin Q$. All signing-oracle queries may be adaptive. This is ordinary, not strong, unforgeability: a new signature on an already queried message is not a forgery and is not needed by our proof.

Let $H : \{0, 1\}^* \rightarrow \{0, 1\}^\kappa$ be collision resistant. We write $\text{Adv}_H^{\text{cr}}(\mathcal{C})$ for the probability that $\mathcal{C}$ outputs two strings $x \neq x'$ for which $H(x) = H(x')$. Probability is over the adversary’s coins and any public hash-parameter generation. Signature correctness requires $\text{Verify}(pk, m, \text{Sign}(sk, m)) = 1$ for keys generated by Kg and every message in the signing domain, except with negligible probability.

The theorem treats the signature and hash assumptions as computational. The issue-and-consume and mediation interfaces in Section 3 are ideal state resources. Their properties are not consequences of EUF-CMA or collision resistance; the real-resource corollary accounts for violations separately.

2.3 Typed authorization language

An action a is a value in a closed typed action grammar. Its encoding $\text{Enc}_A(a)$ is deterministic and injective. A parser rejects unknown members, missing required members, duplicate members, invalid types, non-canonical numbers, and invalid text encodings. A transport such as deterministic CBOR or JCS can implement the wire representation, but the security premise is the injectivity of the complete typed profile, not the name of the transport.

Formally, let $\mathcal{D}$ be the tagged disjoint union of byte strings, canonical text strings, unsigned integers, domain identifiers, audience and principal identifiers, canonical public-key encodings, slots, actions, policy vectors, and finite tuples of those types. We require an efficiently computable, prefix-free encoding $\text{Enc} : \mathcal{D} \rightarrow \{0, 1\}^*$ with an efficient inverse on its image. Every constructor has a distinct fixed tag, every variable-length member is length-prefixed, and vectors encode their length and ordered members. Public-key equality means equality of the canonical key encoding. Enc_A and the context encoding below are restrictions of this one typed encoding. This condition rules out both cross-type ambiguity and concatenation ambiguity.

A pinned-slot policy is an ordered vector of length $1 \leq t \leq N$,

$$\Pi = ((s_1, z_1, pk_{j_1}), \dots, (s_t, z_t, pk_{j_t})),$$

where slot labels s_k , enrolled principal identifiers z_k , and keys pk_{j_k} are pairwise distinct and every pair (z_k, pk_{j_k}) belongs to the certified enrollment relation defined below. The theorem is restricted to all-of- t policies; threshold and other monotone access structures are outside its scope.

Let p be an immutable policy-version commitment, i the initiating principal, r the relying-party audience, d the enforcement domain, and q a λ -bit instance chosen without replacement by a trusted issuer for the lifetime of the experiment. Define

$$h = H(\text{Enc}(\text{ANA-ACTION-v1}, \text{Enc}_A(a))), \quad c = (d, h, p, i, r, \Pi, q).$$

The context encoding $\text{Enc}_C(c)$ and the outer message encoding below are deterministic and injective on their closed grammars. No slot nonce is needed: q gives instance uniqueness and s_k separates slots. The signed message for slot s_k is

$$m(c, s_k) = \text{Enc}(\text{ANA-SIGN-v1}, c, s_k).$$

The admission key is

$$u = H(\text{Enc}(\text{ANA-ADMIT-v1}, c)).$$

Choosing q without replacement is an ideal stateful interface, not a claim that an ordinary random nonce is collision-free. A realization may use a durable monotone or randomly permuted identifier space, or it must add the probability of instance collision and adversarial guessing to the deployment bound.

Enrolled ANA keys are purpose-separated: no signing interface outside the experiment may produce signatures under those keys on the **ANA-SIGN-v1** domain. Equivalently, every legitimate interface capable of signing that domain is represented by **SignCtx** and emits the same signing event. Without this premise, a valid signature from an unmodeled legitimate oracle need not be an EUF-CMA forgery and need not have the witness required by ANA. Including d in c prevents a signature gathered for one enforcement domain from crossing into another. Including Π makes the complete set of pinned slots and keys part of every signature. Including i permits an executor to enforce separation against the issuer-recorded initiator identifier rather than against a mutable label.

2.4 Certified-key model

The challenger samples all N key pairs independently and defines the certified enrollment relation $\text{Cert} = \{(z_j, pk_j) : j \in [N]\}$ before the game. If two canonical public-key encodings coincide, it records **KeyCollision** and aborts the experiment. Principal identifiers are unique by construction. The challenger rejects a policy containing a pair outside Cert , a duplicate key, duplicate identifier, or duplicate slot. This prevents a collector from relabeling pk_j as another enrolled principal. Enrollment, proof of possession, and the binding from an

identifier to a natural person are outside the theorem. The result speaks about distinct enrolled keys and identifiers, not distinct human wills.

The challenger also fixes a trusted audience function Aud before play. $\text{Aud}(d)$ is the authenticated relying-party identity expected at enforcement domain d . The collector cannot modify this value. An issued context may carry any audience selected through the chosen-context interface, but it is admissible at d only when its signed r equals $\text{Aud}(d)$.

The experiment lets the adversary choose the field i in an issuance query and therefore proves only that no approver identifier equals the *issuer-recorded* i . A deployment claiming initiator–approver separation must authenticate the initiating principal and require the trusted issuer to set i from that authenticated identity. It must not copy i from an untrusted collector.

An adversary may reveal sk_j . Authenticity for key j ends at the first reveal event. A later reveal does not alter a previously ordered trace prefix. This is a weak-corruption model, not forward security or offline anti-backdating.

3 Exact Issue, Consume, and Mediation Resources

The cryptographic proof uses two explicit stateful resources. Writing them down prevents a verbal “single-use” claim from entering the theorem as an unstated database assumption.

3.1 Exact issue-and-consume resource

For each domain d , resource $\mathcal{F}_{\text{IC}}$ stores a durable map R_d . Each value contains the complete immutable context, not merely a status bit.

```

IssueExact(d, u, c, a):
  if no exact prior ValidatedIssueInput(d,u,c,a): return false
  if u has ever appeared in R_d: return false
  R_d[u] <- (context=c, status=unused)
  emit Issued(d,u,c,a) at the same linearization point
  return true

Lookup(d, u):
  return R_d[u] or bottom

ConsumeExact(d, u, c):
  if R_d[u] != (context=c, status=unused): return bottom
  allocate a never-before-used ideal handle tau
  R_d[u].status <- consumed
  emit Consumed(d,u,c,tau)
  return tau

```

Calls are linearizable and durable. The record is not visible before its **Issued** event: storage and publication share one linearization point. No transition recreates **unused**. A successful consume is therefore both an exact issuance lookup and a one-time state transition. The resource refuses a caller that presents the right u with different context bytes.

3.2 One-use provider mediator

Resource $\mathcal{F}_{\text{MED}}$ is the only interface that can emit a provider-entry event. On input (d, u, a, c, S, τ) it checks for one unmatched prior $\text{Consumed}(d, u, c, \tau)$ event and one exact prior $\text{ValidatedEntryInput}(d, u, a, c, S, \tau)$ event, parses action digest h from c , and independently checks $h = H(\text{Enc}(\text{ANA-ACTION-v1}, \text{Enc}_A(a)))$. It marks τ used, emits $\text{Entry}(d, u, h, \tau, a, c, S)$ once, and refuses every other call. Carrying the exact action a and validated evidence map S in the trace event makes the security predicate well defined; S need not be sent to the external provider. This is complete mediation at the modeled boundary.

The resource models entry, not effect. A successful call means that the request crossed the boundary. It says nothing about what the provider later did.

4 Security Experiment

4.1 Oracle interface and budgets

Experiment $\text{Exp}_A^{\text{ANA}}(1^\lambda)$ fixes N enrolled keys and gives their public descriptions to $\mathcal{A}$. The adversary makes at most Q_I issuance queries, $Q_{S,j}$ signing queries to key j , Q_A admission queries, and Q_R reveal queries. It controls their interleaving and may invoke admission concurrently.

The challenger provides four oracles.

Issue(d, a, p, i, r, Π).

Validate the closed action, require every policy pair to be in **Cert**, and refuse if an approver identifier equals i . Sample q uniformly from the issuer's as-yet-unused values in $\{0, 1\}^\lambda$, construct c and u , emit **ValidatedIssueInput**(d, u, c, a), and call $\mathcal{F}_{\text{IC}}.\text{IssueExact}(d, u, c, a)$. Refuse if the instance space is exhausted or issuance fails. The resource stores the record and emits **Issued**(d, u, c, a) at one linearization point; only then return (u, c) .

SignCtx(j, d, u, s).

Look up (d, u) and require an unused exact context c whose policy assigns (s, z_j, pk_j) to slot s . Compute $m(c, s)$, emit **Signed**($j, d, u, c, s, m(c, s)$), and return **Sign**($sk_j, m(c, s)$). Thus the adversary chooses every semantic field except the issuer's fresh q , may obtain signatures on arbitrarily many chosen issued contexts, and may later discard or splice the artifacts.

Reveal(j). Emit **Revealed**(j) and return sk_j . Repeated calls have no additional effect.

Admit(d, u, a, S).

Run the construction in Section 6, where S is a finite map of presented slot signatures with duplicates rejected, and the executor obtains its expected audience from the trusted function **Aud**(d). Return its result.

Malformed queries are refused without emitting a security event. The challenger records a totally ordered trace of oracle calls and resource linearization points. This ordering is part of the experiment; the paper does not claim an offline verifier can reconstruct it after key compromise.

The pseudocode below summarizes the experiment. Where it omits detail, the oracle definitions above control.

```

Exp_ANA^A(1^lambda):
  generate N certified signing keys independently; initialize empty trace T
  if two canonical public keys coincide: emit KeyCollision; return 1
  initialize F_IC and F_MED; publish public keys and public parameters
  run A with adaptive access to Issue, SignCtx, Reveal, and Admit
  append each oracle event and resource linearization point to T
  if an Entry in T has no exact authorization witness: return 1
  if two Entries in one domain carry the same admission key u: return 1
  return 0

```

The adversary chooses every action, policy commitment, initiator label, audience, pinned-slot policy, signature query, reveal time, evidence set, and admission schedule permitted by the interfaces. The challenger chooses keys and the fresh issuance value q . There is no hidden challenge bit. The win event is an invalid trace correspondence, which makes the game closer to a computational safety experiment than to indistinguishability.

Table 2 compares our adversary model with nearby variants that are outside the theorem.

Table 2: Chosen-context model and adjacent variants.

Axis	This paper	Boundary
Context choice	adaptive, before each issuance	arbitrary untyped bytes are rejected by the closed grammar
Signers	multiple certified keys; all-of- t pinned slots	general threshold and hidden-signer policies are not proved
Corruption	adaptive key reveal; authenticity ends at prior reveal	no forward security or post-compromise offline dating
Admission	concurrent, adversarially scheduled	ideal resources linearize exact consume and mediate entry
Counted event	provider entry per issued (d, u)	semantic budgets across fresh issuances and physical effects are excluded

4.2 Entry witness

The following predicate instantiates the generic scheme syntax with the typed context and trace events defined in this paper. It is reusable by schemes that expose the same exact issuance, signing, validation, consume, and entry relations; it is not a black-box claim about authorization APIs that expose no such events.

Let $e = \text{Entry}(d, u, h, \tau, a, c, S)$ occur at trace position t_e . The event has an *exact authorization witness* if there is a unique prior $\text{Issued}(d, u, c, a)$ event satisfying all of the following:

1. there is an exact prior $\text{ValidatedIssueInput}(d, u, c, a)$ event, and

$$\begin{aligned} u &= H(\text{Enc}(\text{ANA-ADMIT-v1}, c)), \\ c &= (d, H(\text{Enc}(\text{ANA-ACTION-v1}, \text{Enc}_A(a))), p, i, r, \Pi, q), \end{aligned}$$

whose action digest equals h ;

2. for every $(s_k, z_k, pk_{j_k}) \in \Pi$ whose key was not revealed before t_e , a prior event $\text{Signed}(j_k, d, u, c, s_k, m(c, s_k))$ exists;
3. S is a finite slot-to-signature map whose domain is exactly the slot set of Π , each σ_k verifies under its pinned key on the exact message $m(c, s_k)$, the signed audience satisfies $r = \text{Aud}(d)$, the policy entries are pairwise distinct, and no z_k equals the signed initiator i ; and
4. one prior $\text{Consumed}(d, u, c, \tau)$ event exists and τ witnesses no other provider entry.

The witness does not say that the approvers met, signed simultaneously, knew about one another, or perceived a faithful display. It proves common authorization-instance coherence over c .

Definition 1 (Authorization non-amplification). *Adversary $\mathcal{A}$ wins the ANA experiment if any of the following occurs:*

1. *KeyCollision occurs during setup;*
2. *an entry occurs without an exact authorization witness; or*
3. *two distinct entries in the same enforcement domain contain the same admission key u .*

Its advantage is $\text{Adv}_{\mathcal{A}}^{\text{ana}} = \Pr[\text{Exp}_{\mathcal{A}}^{\text{ANA}} = 1]$.

We also write $\text{Adv}_{\mathcal{A}}^{\text{wit}}$ for the probability of either the setup collision or an entry without an exact authorization witness. Separating this quantity keeps key-generation and cryptographic authenticity risks distinct from the deterministic one-use guarantee supplied by the ideal state resources.

This definition intentionally gives no authenticity guarantee for a slot whose secret key was revealed before entry. The second, cardinality clause remains in force regardless of key reveal.

5 Separations from Standard Notions

We next separate ANA from EUF-CMA and injective agreement. These notions are not weak; they answer different questions.

5.1 Minimal worked attack

Suppose a trusted issuer creates one context c for action “release invoice 417 for USD 10,000,” domain d , audience r , and a two-slot policy. Both pinned signers approve their exact slot messages. A collector now holds only genuine signatures returned by the signing interface. If two stateless executor replicas each verify the same tuple (d, u, a, S) and each submits the request to the provider, then both signatures remain valid, no new message has been forged, and the signers’ protocol runs remain unchanged. Nevertheless the trace contains two entries for the same (d, u) , so $\text{amp}_T(d, u) = 2$. The attack is an authorization amplification, not an authentication forgery.

The construction in Section 6 refuses the second call because both replicas share one linearizable consume state. The example isolates the omitted mechanism: admission must be serialized before provider entry.

Proposition 1 (Stateless replay impossibility). *Let a complete authorization system expose a stateless admission algorithm whose acceptance of a valid artifact does not change any state shared with a later call. If the same artifact can reach the provider boundary twice, then the system cannot satisfy ANA. For a deterministic complete verifier, the ANA adversary wins with probability one and produces no signature forgery.*

Proof. Obtain one valid artifact through the system’s issuance and signing interfaces, then submit it to two admission calls. Statelessness leaves the second call in the same relevant verification state as the first, so completeness makes both calls accept and emit entries. Every signature was returned by an authorized signing interface, yet two entries use the same issued instance. Thus EUF-CMA, even with perfect message authentication, cannot supply the missing entry bound. A probabilistic verifier with independent fresh coins and one-call acceptance probability p yields the same violation with probability at least p^2 . $\square$

Proposition 2 (A signed random nonce is insufficient). *Adding a fresh nonce to the signed message does not imply ANA if executors do not share an atomic consume transition for that nonce.*

Proof. Replay the complete message, nonce, and genuine signature to two stateless executors. Freshness distinguishes the message from other messages; it does not make either executor learn that the other has accepted it. $\square$

Proposition 3 (Byte unforgeability does not imply semantic coverage). *If two distinct reachable typed contexts $x \neq x'$ can be issued and are accepted under the same signed-byte encoding, an adversary wins the witness clause using one genuine signing query and no EUF-CMA forgery.*

Proof. Ask the signer to sign the common byte string while the semantic record is x , then present the signature with x' . Verification succeeds on the queried bytes, but there is no exact prior semantic signing event for x' . $\square$

Proposition 4 (Signer-to-collector injective agreement does not imply ANA). *Lowe-style injective agreement between an approver and a collector does not imply ANA at an executor boundary.*

Proof. Take any protocol in which each completed collector run has a unique matching approver run on data c . After the collector completes, wrap its accepted transcript in an executor API that emits a provider entry on every call. Replaying that transcript to the API does not create a second collector completion or a second approver run, so the original injective- agreement relation remains true. The wrapper nevertheless emits two entries for one authorization and violates ANA. $\square$

Proposition 5 (ANA does not imply agreement among approvers). *ANA does not imply mutual or injective agreement among the approvers.*

Proof. Approvers may sign sequentially through the chosen-context oracle without communicating or knowing one another. The issue-and-consume resource can still give the resulting entry an exact injective witness. ANA therefore establishes neither mutual awareness nor a peer-to-peer agreement run. $\square$

The executor event is the missing endpoint in the first construction. ANA can be written as an injective correspondence from provider entries to issue, consume, and signing events. The chosen-context experiment turns that cross-role correspondence into a computational target and identifies the state and mediation resources needed to realize it.

6 Construction

The following construction realizes the experiment for any all-of- t pinned-slot policy.

```

Issue(d, a, p, i, r, Pi):
  validate the closed action grammar and certified pinned-slot policy
  require 1 <= |Pi| <= N
  reject if an approver id in Pi equals initiator id i
  q <- uniform unused value in the issuer's {0,1}^lambda instance set
  h <- H(Enc("ANA-ACTION-v1", Enc_A(a)))
  c <- (d, h, p, i, r, Pi, q)
  u <- H(Enc("ANA-ADMIT-v1", c))
  emit ValidatedIssueInput(d, u, c, a)
  reject unless F_IC.IssueExact(d, u, c, a) = true
  return (u, c)

Approve(sk_j, d, u, c, s_j):
  reject unless F_IC.Lookup(d, u) = (c, unused)
  reject unless Pi in c assigns (s_j, z_j, pk_j)
  m_j <- Enc("ANA-SIGN-v1", c, s_j)
  sigma_j <- Sign(sk_j, m_j)
  emit Signed(j, d, u, c, s_j, m_j)
  return (s_j, sigma_j)

Admit(d, u, a, S):
  (c, status) <- F_IC.Lookup(d, u); reject unless status = unused
  parse c as (d_c, h, p, i, r, Pi, q) under the closed grammar
  reject unless d_c = d
  reject unless r = Aud(d)
  reject unless h = H(Enc("ANA-ACTION-v1", Enc_A(a)))
  reject unless Pi has unique slots, ids, and certified pinned keys
  reject if an approver id in Pi equals initiator i
  reject unless S is a map whose domain is exactly the slot set of Pi
  for each (s_j, z_j, pk_j) in Pi:
    sigma_j <- S[s_j]
    m_j <- Enc("ANA-SIGN-v1", c, s_j)
    reject unless Verify(pk_j, m_j, sigma_j) = true
  tau <- F_IC.ConsumeExact(d, u, c); reject if tau = bottom
  emit ValidatedEntryInput(d, u, a, c, S, tau)
  return F_MED.Enter(d, u, a, c, S, tau)

```

The executor constructs a from the operation it is about to submit. It does not accept a descriptive action label as a substitute for the provider request. The policy commitment p identifies an immutable policy version. The audience r prevents a signature collected for one relying party from being presented as authority for another. The complete policy Π is signed, so a collector cannot add, remove, or replace a required slot after gathering signatures. When a deployment uses i for separation of duties, the trusted issuer must derive it from the authenticated initiating principal as described above.

The construction places validity windows and clocks outside the core theorem. A deployment may add a typed validity object to c and refuse it under a defined trusted-time policy. Merely writing a timestamp into c would not prove clock correctness or anti-backdating, so the core claim does not depend on one.

7 Security Analysis

The proof has three layers. Exact-context binding reduces semantic substitution to an encoding failure or hash collision. Exact-witness authenticity reduces an accepted signature without a prior signing event to EUF-CMA. Ideal non-amplification follows separately from the linear state resources. The final corollary composes those results; it does not derive state correctness from cryptography.

Lemma 1 (Exact-context binding). *Consider two issued triples (a, c, s) and (a', c', s') . Conditioned on no collision in H , equality $m(c, s) = m(c', s')$ implies equality of their enforcement domain, action, policy commitment, initiator, audience, pinned-slot policy, authorization instance, and slot.*

Proof. Injectivity of the outer closed encoding gives equality of the literal domain label, both contexts, and the slot. Equality of the contexts gives equality of every directly encoded field and of the action digests. If the canonical action encodings differed, the equal digests would be a collision in H . $\square$

Lemma 2 (Functional completeness conditioned on correctness). *Assume the ideal resources and condition on every honest signature generated in this execution verifying under its generated public key. If **Issue** returns (u, c) , every slot in the nonempty policy is approved through **SignCtx** while the record remains unused, and **Admit** is called with the issued action and those signatures at domain d with the issued $r = \text{Aud}(d)$, then the first admission emits one provider entry. Every later admission for the same (d, u) is refused.*

Proof. Signature correctness makes every pinned verification succeed. The issued action reproduces the digest in c , and the certified policy satisfies the deterministic structural checks. The first exact consume therefore returns a fresh mediator token, which the mediator accepts once. The consume changes the record to **consumed**, so a later lookup or consume cannot reach entry. $\square$

Lemma 3 (Ideal non-amplification). *With $\mathcal{F}_{\text{IC}}$ and $\mathcal{F}_{\text{MED}}$, two provider entries in one domain cannot contain the same admission key u .*

Proof. Every entry consumes one fresh mediator token produced by a successful **ConsumeExact** (d, u, c) . Linearizability totally orders consumes for u . The first success changes the unique exact record from **unused** to **consumed**; no rule recreates **unused**. A second consume for u cannot succeed. The mediator also refuses reuse of the first token. $\square$

Theorem 1 (Exact-witness authenticity with ideal resources). *Let **Sig** be EUF-CMA secure, H collision resistant, and the declared typed encodings injective. For every probabilistic polynomial-time adversary $\mathcal{A}$ using at most N enrolled keys, Q_I issuance queries, $Q_{S,j}$ signing queries to key j , Q_A admission queries, and Q_R reveal queries, there are collision finder $\mathcal{C}_H$ and EUF-CMA forgers $\mathcal{B}_1, \dots, \mathcal{B}_N$ such that*

$$\text{Adv}_{\mathcal{A}}^{\text{wit}} \leq \Pr[\text{KeyCollision}] + \text{Adv}_H^{\text{cf}}(\mathcal{C}_H) + \sum_{j=1}^N \text{Adv}_{\text{Sig}}^{\text{euf-cma}}(\mathcal{B}_j).$$

Forger $\mathcal{B}_j$ makes at most $Q_{S,j}$ signing-oracle queries. Its simulation generates $N-1$ key pairs, locally answers at most $\sum_{\ell \neq j} Q_{S,\ell}$ signing queries, performs at most NQ_A signature verifications, and adds polynomial encoding, hashing, policy, and table work in the stated query bounds. The sum is over the complete enrolled key universe fixed before play, not a policy selected after a win.

Proof. We use five games.

Game G_0 . Run the ANA experiment with the ideal state resources and set the game output to one exactly when setup records **KeyCollision** or an entry lacks an exact witness.

Game G_1 . Set the output to zero on **KeyCollision**. Otherwise continue unchanged. Hence

$$|\Pr[G_0 = 1] - \Pr[G_1 = 1]| \leq \Pr[\text{KeyCollision}].$$

The game samples every key independently and handles the duplicate branch explicitly; it does not condition key generation by resampling.

Game G_2 . Run the identical experiment while recording every input on which the challenger evaluates H ; the domain-separation tags are already part of G_0 . Abort if two distinct recorded inputs have the same digest. A challenger that outputs the first such pair is $\mathcal{C}_H$, so

$$|\Pr[G_1 = 1] - \Pr[G_2 = 1]| \leq \text{Adv}_H^{\text{cr}}(\mathcal{C}_H).$$

Game G_3 . For each $j \in [N]$, abort if an entry's evidence set contains a required valid signature under pk_j , no reveal of j precedes the entry, and the signing table contains no exact prior row $(j, d, u, c, s, m(c, s))$ for that accepted slot. Construct $\mathcal{B}_j$ by embedding its EUF-CMA challenge key as pk_j , generating every other key, and forwarding each **SignCtx** query for j to its signing oracle. It simulates issuance, other signers, the resources, and all public checks exactly; if any canonical public keys coincide, it terminates without a forgery just as G_2 does. The reduction stops when either the fixed- j bad event occurs or j is revealed, whichever comes first. In the former case it outputs the forgery. In the latter, the ANA witness no longer requires authenticity for j , so no subsequent entry can trigger the fixed- j event.

If the G_3 bad event occurs first, the accepted signature verifies on message $m^* = m(c^*, s^*)$. No exact signing row exists. A query on the same bytes under a different semantic context would contradict exact-context binding in G_2 . Thus m^* was not submitted to the EUF-CMA oracle, and the accepted pair is a forgery. A union bound over the key universe gives

$$|\Pr[G_2 = 1] - \Pr[G_3 = 1]| \leq \sum_{j=1}^N \text{Adv}_{\text{Sig}}^{\text{euf-cma}}(\mathcal{B}_j).$$

Game G_4 . Associate every accepted unrevealed slot with its exact prior signing-table row. This changes no probability. The exact issue lookup fixes one context c for u ; the validated issue-input event binds the exact issuer input, while outer-encoding injectivity and the G_2 condition make every signed field equal to that context. The mediator's independent digest check binds the exact action carried by the entry. The deterministic checks enforce the trusted audience, unique pinned keys and slots, and exclusion of the signed initiator. Hence every entry has the required witness.

No unwitnessed-entry condition remains in G_4 , so $\Pr[G_4 = 1] = 0$. Summing the game differences proves the authenticity bound. The stated query and runtime costs follow directly from the simulation. $\square$

Corollary 1 (Per-issuance ANA composition). *Under the assumptions of the exact-witness theorem and the ideal $\mathcal{F}_{\text{IC}}$ and $\mathcal{F}_{\text{MED}}$ resources,*

$$\text{Adv}_{\mathcal{A}}^{\text{ana}} \leq \Pr[\text{KeyCollision}] + \text{Adv}_H^{\text{cr}}(\mathcal{C}_H) + \sum_{j=1}^N \text{Adv}_{\text{Sig}}^{\text{euf-cma}}(\mathcal{B}_j).$$

Proof. The theorem bounds the probability of a setup-key collision or an unwitnessed entry. Ideal non-amplification deterministically excludes the duplicate-entry winning condition. The corollary is therefore a composition of a cryptographic authenticity result with an explicit state invariant; it is not a claim that signatures create one-time state. $\square$

7.1 Concrete interpretation

If every per-key EUF-CMA advantage is at most ϵ_{sig} , the hash-collision advantage is at most ϵ_H , and the probability of a duplicate canonical public key is at most ϵ_{key} , the theorem and composition corollary give

$$\text{Adv}_{\mathcal{A}}^{\text{ana}} \leq \epsilon_{\text{key}} + N\epsilon_{\text{sig}} + \epsilon_H.$$

The N factor is deliberately conservative. It avoids a post-selected two-key bound when an adversary can range over many enrolled keys and policies.

The theorem is not a durability proof for a database or a code-level proof of complete mediation. The next corollary states exactly what a real deployment must add.

7.2 Real-resource refinement

Let R and M be probabilistic polynomial-time implementations of the issue-and-consume and mediation interfaces. Experiment $\text{Exp}_{\mathcal{A},R,M}^{\text{ANA},\text{real}}(1^\lambda)$ is the ANA experiment of Section 4 with R and M substituted for the ideal resources. It records their atomic issuance, consume, validation, and provider-entry events in the same ordered trace and applies the same ANA winning predicate. Write $\text{Adv}_{\mathcal{A},R,M}^{\text{ana},\text{real}}$ for its winning probability. In that experiment, define:

- **RegistryBreak** occurs if any of these conditions holds:
 - (R1) a record becomes visible without exactly one atomic **Issued**(d, u, c, a) event matching an exact prior **ValidatedIssueInput**(d, u, c, a) event;
 - (R2) one (d, u) has two or more issuance events, including byte-identical duplicates;
 - (R3) a stored, returned, or consumed tuple differs from the validated issue input;
 - (R4) a successful consume lacks the unique exact issuance;
 - (R5) a successful consume does not atomically emit exactly one matching **Consumed**(d, u, c, τ) event, including a different returned token or tuple; or
 - (R6) two consumes for the same u both succeed.
- **MediationBreak** occurs if any of these conditions holds:
 - (M1) a provider entry lacks one unmatched prior **ValidatedEntryInput**(d, u, a, c, S, τ) event and one exact prior **Consumed**(d, u, c, τ) event;
 - (M2) the exact action a , its digest h , or the exact evidence map S changes between validation and entry; or
 - (M3) one token witnesses two entries.

These are trace events in a stated experiment, not undefined labels for “something went wrong.” Their probabilities must be justified by a refinement proof, transactional implementation argument, or measured fault model for the deployment.

Corollary 2 (Deployment composition). *Replacing the ideal resources by implementations R and M gives*

$$\begin{aligned} \text{Adv}_{\mathcal{A},R,M}^{\text{ana},\text{real}} &\leq \Pr[\text{KeyCollision}] + \text{Adv}_H^{\text{cr}}(\mathcal{C}_H) \\ &\quad + \sum_{j=1}^N \text{Adv}_{\text{Sig}}^{\text{euf-cma}}(\mathcal{B}_j) \\ &\quad + \Pr_{\text{Exp}_{\mathcal{A},R,M}^{\text{ANA},\text{real}}}[\text{RegistryBreak}] \\ &\quad + \Pr_{\text{Exp}_{\mathcal{A},R,M}^{\text{ANA},\text{real}}}[\text{MediationBreak}]. \end{aligned}$$

Proof. Conditioned on neither implementation event, the observed issue, consume, and entry trace satisfies the two ideal-resource safety relations used in the composition result. Apply that result and then a union bound over the two implementation events. $\square$

The corollary keeps operational correctness visible. It would be misleading to call either implementation probability negligible merely because the signatures are cryptographically strong. This is an in-model resource decomposition: the environment still reaches the provider only through the mediator. A deployment claiming complete mediation must separately show that no alternate provider path can emit an unrecorded entry.

8 Trace-Prefix Authenticity and Backdating

Lemma 4 (Trace-prefix authenticity). *Suppose an entry whose evidence set contains a required valid signature under pk_j occurs at position t_e , no reveal of sk_j precedes t_e , and a reveal occurs later. Except with probability bounded by the corresponding EUF-CMA and collision advantages, the exact signing event for the accepted slot precedes t_e .*

Proof. Stop the experiment at t_e . The later reveal is outside the prefix and does not change its distribution. The G_2 – G_3 argument from the exact-witness theorem then gives the exact prior signing event. $\square$

Proposition 6 (Ordinary signatures do not prove offline anti-backdating). *After learning sk_j , an adversary can create a valid signature on a message containing an earlier claimed timestamp. An offline verifier given only (m, σ, pk_j) cannot distinguish it from a signature produced before compromise.*

Proof. The adversary runs the honest signing algorithm after compromise. The timestamp is only signed data; it is not an independently ordered event. Both signatures satisfy the same verification relation. $\square$

Forward-secure signatures or an independently witnessed append-only checkpoint can support a stronger statement. Neither is part of the ANA construction.

9 Symbolic Case Studies

Four public Tamarin theories [34] test concrete single-approval, 2-of-2, and composed instances against a Dolev–Yao adversary that controls the network and can solicit honest signatures on chosen authorization contexts. The theories are not a substitute for the computational theorem: they idealize signatures and typed encoding, and their linear facts assume the state transitions they represent.

The representative positive lemma `injective_acceptance_with_consumption` verifies in 11 proof steps. Its deliberately weakened companion removes linear consumption and finds the expected 11-step trace: one genuine artifact is accepted twice. The quorum model also found an earlier initiator-substitution trace when the initiator was omitted from the signed context; binding that field removes the trace.

The full result list and nine weakened comparisons appear in Appendix A. The focused models correspond to the construction’s exact-signature and one-use obligations. The composed models test additional EMILIA reliance checks outside the computational theorem. None of the models is a mechanized refinement proof of the ideal state resources.

10 Relation to Prior Work

Table 3 compares the closest security targets by what the adversary may collect, what endpoint is counted, and which principal boundary is protected. These axes are narrow; the table does not rank the works overall.

Table 3: Closest security targets and the object each one counts.

Target	Adversarial collection	Counted endpoint	Principal boundary
EUF-CMA [1]	adaptive message queries	previously unsigned message	does not count execution
Injective agreement [2]	protocol-run adversary	matching peer run	downstream entry may replay
Spent-state and stateful authorization [19, 12]	history or spend reuse	spend or policy-history event	not an exact multi-signer entry witness
SUDP and CapLease [23, 14]	delegated use or semantic reissuance	grant use or action-level budget	different collector and witness models
Per-issuance ANA	adaptive chosen contexts and concurrent presentation	provider entry per issued (d, u)	exact pinned multi-signer context

Authentication and injective agreement. Bellare and Rogaway’s matching-conversation model and Lowe’s hierarchy make session correspondence explicit; Lowe distinguishes aliveness, weak agreement, non-injective agreement, and injective agreement between protocol participants [3, 2]. ANA borrows the discipline of explicit correspondence events but changes the relation being counted: provider entries must map injectively to trusted issued authorization instances. Proposition 4 shows a protocol can preserve signer-to-collector injective agreement while a downstream executor amplifies one completed run into several entries. Proposition 5 shows that ANA permits asynchronous signers who never establish mutual agreement. We do not claim a new general logic of correspondence assertions. The new object is the chosen-context authorization experiment and its exact executor-entry witness.

Computational authorization proofs. Wang et al. give a computationally sound mechanized analysis of TPM 2.0 authorization protocols [4]. Barbosa et al. give a modular computational analysis of WebAuthn and CTAP2 [5]; Guan et al. and Schrempf study FIDO2 symbolically, including a human role [6, 7]. Those works analyze the security of their authorization or authentication ceremonies. ANA assumes an enrolled signature interface and places the collector under chosen-context adversarial control. Its proof target also includes executor entry, and its failure measure is the number of entries attributable to one issued authorization.

Agent authorization gateways and records. OAP intercepts tool calls before execution and produces signed audit records [15]. aiAuthZ moves identity- and policy-bound authorization off the agent host and uses an atomic single-use nonce store [16]. AgentBound describes receipts binding an action to delegation, policy, and semantic artifacts [17]. Llambí-Morillas and Fernández-Fernández formalize principal, request, context, and policy binding and identify request-to-runtime execution binding as an open research problem [18]. These systems already provide pre-action gateways, operation binding, and signed records. ANA addresses a different question: whether exact multi-signer evidence remains non-amplifying when a collector may harvest chosen-context signatures. We answer it with a multi-user EUF-CMA and collision-resistance reduction tied to the executor-entry event.

Transaction authorization and trusted display. Van Herreweghen and Wille analyze which Internet-payment security requirements an EMV deployment does and does not meet [8]. “See what you sign” makes trusted input and output part of binding a signature to human intent [9]; Notary builds a trusted device for transaction approval [10]. ANA does not solve the display problem. It ensures that the executor cannot accept a different typed action from the one covered by the signature and cannot admit the same issued instance twice.

Stateful authorization. Formal analyses of PKCS#11 show that mutable state can be integral to a security claim [11]. StatefulAuth protects authorization policies that depend on request history [12]. Macaroons provide decentralized attenuation through contextual caveats [13]. ANA focuses on a different state relation:

exact issue-and-consume state must injectively connect one signed authorization to one provider entry under concurrent presentation.

The need for spent-artifact state is classical rather than new. Online digital cash prevents double spending through a bank’s spent-coin state, while offline schemes detect it after deposit [19]. Linearizability supplies the concurrent-object semantics used by the ideal consume operation [21], and complete mediation supplies the reference-monitor principle behind the executor boundary [22]. ANA’s contribution is not the observation that replay needs state. It is the cryptographic experiment connecting malicious chosen-context collection, multi-signer typed evidence, exact issuance, and the provider-entry event.

Anonymous counting tokens let an issuer enforce a per-client issuance rate, including one token per client per message, while retaining the privacy goals of anonymous tokens [20]. That is an issuance-side cryptographic limit. ANA does not provide anonymity and assumes a trusted issuer has already created an instance; its question is whether a malicious collector can turn the exact multi-signer evidence for that instance into more than one provider entry.

SUDP gives an operation-bound, authenticator-backed single-use grant redeemed by a custodian so the agent never receives a reusable secret [23]. Krenn and Lorünser use smart-contract state to enforce a user-defined bound on delegated signature invocations [24]. Both demonstrate that single use can be built with a stateful redemption boundary. ANA differs in the adversary and witness: a malicious collector may harvest signatures for many issued contexts, and each executor entry must point to the exact multi-signer context and policy that survived that collection.

Lie and Marsh define ledger-authenticator unforgeability for reactive authorization judged against a finalized transcript, with adaptive corruption and a multi-user QROM bound [28]. ANA has no ledger, finality, or quantum-random-oracle claim. Its trace order comes from the experiment, and its later-reveal result is only prefix authenticity. In return, ANA makes multi-signer exact-action artifacts and the non-ledger executor admission event the object of the reduction.

Xu et al. identify *semantic replay*: a system can consume every token once and still issue fresh identifiers against the same underlying confirmation until its action-level budget is exceeded [14]. Their CapLease construction uses durable token-independent state to bound reissuance, admission, and recovery. That result is complementary and sets an important boundary on this paper. ANA is per issued instance (d, u) ; it does not stop a trusted issuer from creating a new (d, u') for semantically equivalent authority. ANA instead gives a computational chosen-context account of the evidence needed for one issued instance: exact issuer registration, prior signing events on every exact pinned-slot message for each then-unrevealed required key, and an injective map to provider entry. A system that needs a budget spanning several issued instances must compose ANA with a durable action- or confirmation-level ledger.

Policy-aware and threshold cryptography. Policy-Compliant Signatures make policy satisfaction part of an enhanced signature primitive, and attribute-based signatures hide signers behind attribute predicates [29, 30]. Bellare and Neven formalize multisignatures in which several certified public keys jointly authenticate one common document [25]; threshold signatures likewise can make several shares verify as one signature. ANA instead uses ordinary signatures under explicitly pinned keys and exposes each required slot. Replacing those signatures with a policy-aware or threshold primitive would not remove the need for exact issuance and one-time consumption at the executor boundary.

Non-amplification terminology. The phrase *non-amplification* has prior uses with different counted objects. Maffei, Mitchell, and Taly require “No Authority Amplification” as part of authority safety for object-capability isolation [26]. Xu et al. use *source-authority non-amplification* to prevent lossy agent memory consolidation from increasing the trust assigned to source information [27]. Neither property counts provider entries per issued authorization instance. We use ANA as a descriptive name for the trace property in Definition 1, not as a claim of priority over those terms.

Concrete formats. Compare lifts bit-string security arguments to typed protocol messages under verified format conditions [31]. ANA relies on the same lesson. Its semantic-coverage separation explains why a byte-

level signing oracle is insufficient when an application maps distinct semantic contexts to the same signed bytes. This paper states typed-encoding injectivity as a premise; it does not claim a new verified parser framework.

Logs and temporal evidence. Transparency overlays and forward-secure audit logs can provide independently checkable ordering and post-compromise evidence [32, 33]. ANA’s trace-prefix lemma uses the experiment’s event order and makes no offline anti-backdating claim. A deployment that needs that stronger property must add one of those mechanisms.

11 Limitations and Ethics

The certified-key model does not prove that an enrolled key belongs to a named person or that two keys represent independent people. It proves distinct pinned credentials. Directory governance, identity proofing, collusion, coercion, and one-person-many-credentials attacks remain separate.

The collector may render action X while causing a signing device to sign the digest of action Y . ANA requires the admitted action to reproduce that signed digest and prevents the artifact from authorizing a different action Z absent a hash collision. The signature alone does not reveal Y , and the property cannot prove what the approver saw. High-consequence deployments need a trusted or independently authored display path.

The theorem covers a finite enrolled key universe and all-of- t pinned-slot policies. It does not cover arbitrary threshold policies, dynamic key-directory updates, clock synchronization, policy authorship, or transparency-log consistency. It assumes the executor derives the canonical action from the operation it is about to submit.

The pair (d, u) is the unit counted by ANA. If an issuer creates a fresh (d, u') from the same human confirmation or an equivalent action, both instances may each be admitted once without violating ANA. Preventing that semantic replay requires durable state and a budget above the per-instance registry [14]; it is not implied by this construction.

The negative models analyze synthetic traces and remove one protocol check at a time; they do not probe or exploit a deployed service.

Most importantly, provider entry is not physical truth. An entry may have no effect, one effect, or an effect whose acknowledgement is lost. When the outcome is indeterminate, ANA keeps the authorization consumed and requires separate authenticated reconciliation. It does not authorize a blind retry.

12 Conclusion

Cryptographic authorization needs an explicit unit of account. EUF-CMA counts new signed messages. A consequential system must also count admitted actions. Per-issuance ANA makes that second count precise: every provider entry needs an exact prior issuance and exact signing witnesses for all then-unrevealed required keys, while one issued instance may not witness two entries.

The analysis separates obligations that should not be collapsed. Signatures, collision resistance, and typed encoding establish the exact-context witness. Atomic issue-and-consume state and evidence-preserving complete mediation establish the one-use bound. The former is a cryptographic reduction; the latter is an explicit systems invariant. The real-resource corollary keeps their failure probabilities separate.

This distinction is the paper’s result. A collector may complete one genuine signer run and still replay its output through a downstream executor. Conversely, an entry may have an exact authorization witness even when its approvers never communicate. The experiment captures the cross-role relation without claiming human intent, semantic budgets across fresh issuances, or exactly-once physical effects.

Artifact Availability

The four Tamarin case-study theories, rerun scripts, and pinned tool summaries are available at <https://github.com/emiliaprotocol/emilia-protocol/tree/c3e5da51d656f56470c2d568cd6295cb842893cf>. They are not a mechanized refinement proof of the construction in this paper. The relevant theories are:

```
formal/tamarin/ep_receipt_core.spthy
formal/tamarin/ep_quorum_core.spthy
formal/tamarin/ep_reliance_composed.spthy
formal/tamarin/ep_six_claim_composed.spthy
```

The source for this version is maintained in the public repository alongside the Tamarin artifacts. The v3 predecessor is archived at [doi:10.5281/zenodo.21968577](https://doi.org/10.5281/zenodo.21968577).

A Machine-Checked Case-Study Results

The focused Tamarin models report the following results with Tamarin 1.10.0 and Maude 3.4:

```
executable_honest_receipt: verified (9 steps)
core_authenticity_uv_gated: verified (11 steps)
acceptance_prefix_integrity_after_later_reveal: verified (12 steps)
no_replay_across_actions: verified (11 steps)
injective_acceptance_with_consumption: verified (11 steps)
unchecked_acceptance_is_injective: falsified (11 steps)

executable_quorum: verified (13 steps)
quorum_requires_two_distinct_uv_gated_signatures: verified (27 steps)
initiator_cannot_self_approve: verified (4 steps)
no_single_signer_fills_quorum: verified (4 steps)
commit_requires_signature_over_that_action: verified (8 steps)
```

The composed theories add exact action identity, current registry view, revocation state, issuer pinning, authority scope, profile pins, one-time consumption, and entry. Table 4 lists the nine weakened comparisons. These are symbolic separations with idealized signatures, not empirical deployment results.

Table 4: Machine-found separations with ideal signatures unchanged.

Comparison	Removed check	Counterexample consequence
Focused double acceptance	linear consumption	one genuine approval accepted twice
Composed double entry	shared consume fact	one authorization reaches entry twice
Stale-head laundering	exact current registry head	narrowed authority accepted under an old view
Class downgrade	minimum assurance class	weaker evidence satisfies a stronger class
Denial becomes authority	denial non-authorization	signed denial treated as permission
Scope expansion	authority-scope pin	out-of-scope action admitted
Profile swap	complete profile pin	different verification profile substituted
Phantom challenge	registration before exposure	unregistered challenge accepted
Action-key swap	canonical action-key binding	evidence for one action keys entry for another

References

- [1] S. Goldwasser, S. Micali, and R. Rivest, “A Digital Signature Scheme Secure Against Adaptive Chosen-Message Attacks,” *SIAM Journal on Computing*, 17(2), pp. 281–308, 1988.
- [2] G. Lowe, “A Hierarchy of Authentication Specifications,” *10th IEEE Computer Security Foundations Workshop*, pp. 31–43, 1997. <https://doi.org/10.1109/CSFW.1997.596782>.

- [3] M. Bellare and P. Rogaway, “Entity Authentication and Key Distribution,” *CRYPTO 1993*, LNCS 773, pp. 232–249, 1994. <https://www.cs.ucdavis.edu/~rogaway/papers/eakd-abstract.html>.
- [4] W. Wang, Y. Qin, and D. Feng, “Automated Proof for Authorization Protocols of TPM 2.0 in Computational Model,” *ISPEC 2014*, LNCS 8434, pp. 144–158, 2014. https://doi.org/10.1007/978-3-319-06320-1_12.
- [5] M. Barbosa, A. Boldyreva, S. Chen, and B. Warinschi, “Provable Security Analysis of FIDO2,” *CRYPTO 2021, Part III*, LNCS 12827, pp. 125–156, 2021. https://doi.org/10.1007/978-3-030-84252-9_5.
- [6] J. Guan, H. Li, H. Ye, and Z. Zhao, “A Formal Analysis of the FIDO2 Protocols,” *ESORICS 2022*, LNCS 13556, pp. 3–21, 2022. https://doi.org/10.1007/978-3-031-17143-7_1.
- [7] L. Schrempp, “Formal Verification of FIDO2 with Human Interaction,” Master’s thesis, ETH Zurich, 2023. <https://doi.org/10.3929/ethz-b-000610315>.
- [8] E. Van Herreweghen and U. Wille, “Risks and Potentials of Using EMV for Internet Payments,” *USENIX Workshop on Smartcard Technology*, 1999. <https://www.usenix.org/conference/usenix-workshop-smartcard-technology/risks-and-potentials-using-emv-internet-payments>.
- [9] A. Weber, “See What You Sign: Secure Implementations of Digital Signatures,” *5th International Conference on Intelligence and Services in Networks*, LNCS 1430, pp. 509–520, 1998. <https://doi.org/10.1007/BFb0056995>.
- [10] A. Athalye, A. Belay, M. F. Kaashoek, R. Morris, and N. Zeldovich, “Notary: A Device for Secure Transaction Approval,” *27th ACM Symposium on Operating Systems Principles*, pp. 97–113, 2019. <https://doi.org/10.1145/3341301.3359661>.
- [11] S. Delaune, S. Kremer, and G. Steel, “Formal Security Analysis of PKCS#11 and Proprietary Extensions,” *Journal of Computer Security*, 18(6), pp. 1211–1245, 2010. <https://doi.org/10.3233/JCS-2009-0394>.
- [12] L. Cao, L. Meng, D. Stefan, and E. Fernandes, “Stateful Least Privilege Authorization for the Cloud,” *33rd USENIX Security Symposium*, pp. 3477–3494, 2024.
- [13] A. Birgisson, J. G. Politz, U. Erlingsson, A. Taly, M. Vrabie, and M. Lentczner, “Macaroons: Cookies with Contextual Caveats for Decentralized Authorization in the Cloud,” *NDSS*, 2014.
- [14] J. Xu, L. Fan, Z. Wang, X. Li, and H. Liu, “Beyond Single-Use Tokens: Durable Authorization State for Replay-Resistant LLM Agent Actions,” arXiv:2608.01710, 2026. <https://arxiv.org/abs/2608.01710>.
- [15] U. Uchibeke, *Before the Tool Call: Deterministic Pre-Action Authorization for Autonomous AI Agents*, arXiv:2603.20953, 2026. <https://arxiv.org/abs/2603.20953>.
- [16] S. V. Kodathala, *aiAuthZ: Off-Host, Identity-Bound Authorization for AI Agents*, arXiv:2607.05518, 2026. <https://arxiv.org/abs/2607.05518>.
- [17] A. Kaul, Q. Lan, and P. Gupta, *Behavioral Governance for Autonomous AI Agents: The AgentBound Framework*, arXiv:2606.30970, 2026. <https://arxiv.org/abs/2606.30970>.
- [18] M. Llambí-Morillas and D. Fernández-Fernández, *Cryptographically Verifiable Authorization for Autonomous AI Agents: A Falsifiable Hypothesis and Proof-of-Concept*, arXiv:2607.21325, 2026. <https://arxiv.org/abs/2607.21325>.
- [19] D. Chaum, A. Fiat, and M. Naor, *Untraceable Electronic Cash*, CRYPTO 1988, LNCS 403, pp. 319–327, 1990. https://doi.org/10.1007/0-387-34799-2_25.
- [20] F. Benhamouda, M. Raykova, and K. Seth, “Anonymous Counting Tokens,” *ASIACRYPT 2023, Part II*, pp. 245–278, 2023. https://doi.org/10.1007/978-981-99-8724-5_8. <https://eprint.iacr.org/2023/320>.

- [21] M. P. Herlihy and J. M. Wing, *Linearizability: A Correctness Condition for Concurrent Objects*, ACM Transactions on Programming Languages and Systems, 12(3), pp. 463–492, 1990. <https://doi.org/10.1145/78969.78972>.
- [22] J. H. Saltzer and M. D. Schroeder, *The Protection of Information in Computer Systems*, Proceedings of the IEEE, 63(9), pp. 1278–1308, 1975. <https://doi.org/10.1109/PROC.1975.9939>.
- [23] X. Yu, H. Geng, X. Zeng, and W. Knottenbelt, *SUDP: Secret-Use Delegation Protocol for Agentic Systems*, arXiv:2604.24920, 2026. <https://arxiv.org/abs/2604.24920>.
- [24] S. Krenn and T. Lorünser, *Single-Use Delegatable Signatures Based on Smart Contracts*, *ARES 2021*, pp. 1–7, 2021. <https://doi.org/10.1145/3465481.3469192>.
- [25] M. Bellare and G. Neven, “Multi-Signatures in the Plain Public-Key Model and a General Forking Lemma,” *ACM CCS 2006*, pp. 390–399, 2006. <https://doi.org/10.1145/1180405.1180453>.
- [26] S. Maffei, J. C. Mitchell, and A. Taly, “Object Capabilities and Isolation of Untrusted Web Applications,” *31st IEEE Symposium on Security and Privacy*, pp. 125–140, 2010. <https://doi.org/10.1109/SP.2010.16>.
- [27] J. Xu, Y. Xiao, W. Shao, H. Liu, and X. Li, “Memory Provenance Laundering in LLM Agents: A Non-Amplification Firewall for Persistent Memory,” arXiv:2607.29167, 2026. <https://arxiv.org/abs/2607.29167>.
- [28] M. Lie and B. Marsh, *Finality Before Disclosure for Ledger Authenticators in the Quantum Random Oracle Model*, arXiv:2608.18605, 2026. <https://arxiv.org/abs/2608.18605>.
- [29] C. Badertscher, C. Matt, and H. Waldner, “Policy-Compliant Signatures,” *TCC 2021*, LNCS 13044, pp. 350–381, 2021. https://doi.org/10.1007/978-3-030-90456-2_12. <https://eprint.iacr.org/2021/1234>.
- [30] H. Maji, M. Prabhakaran, and M. Rosulek, “Attribute-Based Signatures: Achieving Attribute-Privacy and Collusion-Resistance,” *Cryptology ePrint Archive*, Paper 2008/328, 2008.
- [31] T. Wallez, J. Protzenko, and K. Bhargavan, “Compars: Provably Secure Formats for Cryptographic Protocols,” *ACM CCS*, 2023. <https://doi.org/10.1145/3576915.3623201>.
- [32] M. Chase and S. Meiklejohn, “Transparency Overlays and Applications,” *ACM CCS*, 2016. <https://eprint.iacr.org/2016/915>.
- [33] G. Hartung, “Secure Audit Logs with Verifiable Excerpts,” *CT-RSA*, 2016. https://doi.org/10.1007/978-3-319-29485-8_11.
- [34] S. Meier, B. Schmidt, C. Cremers, and D. Basin, “The TAMARIN Prover for the Symbolic Analysis of Security Protocols,” *CAV 2013*, LNCS 8044, pp. 696–701, 2013.